

Evaluación N°2

Criterios de la Evaluación

- Analiza riesgos sobre la infraestructura TI de la empresa en base a posibles amenazas y vulnerabilidades.
- Evalúa las consecuencias de los posibles ataques detectados.
- Registra las amenazas y vulnerabilidades de los ataques informáticos a los cuales se ha visto comprometida la infraestructura TI de la empresa.
- Identifica la información necesaria y las diversas variables involucradas.

CASO DE ESTUDIO:

MediTech Innovations es un proveedor de servicios en el ámbito de la salud digital. MediTech tiene dos líneas principales de negocios: desarrollo de software para la gestión de pacientes y prestación de servicios de telemedicina. MediTech crea, gestiona y aloja aplicaciones que permiten la interacción entre pacientes y profesionales de la salud. Además, ofrece servicios de pago en línea que permiten a los hospitales y clínicas cobrar a los pacientes por consultas remotas y otros servicios médicos.

MediTech emplea a unas 120 personas en su sede central, con oficinas adicionales en Nueva York y Sídney, donde trabajan aproximadamente 6 personas en cada una. Dado que ofrece servicios de salud y gestiona información médica, MediTech debe cumplir estrictamente con diversas normativas internacionales de privacidad y seguridad, como la HIPAA en los Estados Unidos y las leyes de privacidad de datos en Australia.

MediTech actúa como custodio tanto de su propio software como de los datos médicos de los pacientes de sus socios, que incluyen hospitales y clínicas. Estos datos abarcan historiales clínicos, resultados de pruebas, imágenes diagnósticas y otras informaciones médicas confidenciales. El manejo seguro de estos datos es fundamental para la empresa. Además, MediTech administra la información de cuentas de pacientes, incluyendo registros de citas, autenticación, historiales de consultas y datos de facturación.

MediTech gestiona sus propias bases de datos SQL, algunas de las cuales están conectadas a portales web que permiten a los pacientes y profesionales de la salud acceder a información clave. La infraestructura tecnológica de MediTech se basa en una combinación de dispositivos Windows y móviles Android e iOS. Sus servidores, tanto basados en Microsoft como en Linux, almacenan datos médicos, información

financiera y registros de empleados. El hardware incluye diferentes marcas y antigüedades de PC, así como distintas versiones de sistemas operativos.

Aunque MediTech utiliza servicios en la nube para ofrecer sus soluciones de telemedicina, los datos médicos y los sistemas de desarrollo de software se alojan internamente en servidores seguros. Los empleados pueden usar sus teléfonos y tabletas personales para el trabajo, y algunos trabajan desde casa, con acceso completo a la red corporativa a través de VPN segura. MediTech también aloja sus propios servicios de DNS, correo electrónico e intranet.

Los empleados de MediTech utilizan aplicaciones estándar de oficina, software especializado en gestión médica y herramientas internas desarrolladas para la administración de sistemas médicos. La empresa proporciona acceso a partes de su red interna a sus socios de atención médica mediante un portal web seguro. A través de este portal, los hospitales y clínicas pueden compartir datos de pacientes y subir resultados médicos para su integración en las plataformas de MediTech. Los pacientes acceden a la plataforma de telemedicina gestionada en la nube mediante inicios de sesión seguros.

La tarea es evaluar el entorno tecnológico de MediTech desde una perspectiva de ciberseguridad. Identificar y clasificar los activos clave de la empresa, listar posibles vulnerabilidades y amenazas a las que se enfrenta, y luego recomendar medidas de mitigación para proteger la infraestructura y activos de MediTech.

Parte 1: Registre su evaluación de los problemas de ciberseguridad de MediTech.

NOTA: Estas tablas debe completarla luego de terminar los partes 2, 3 y 4, con los títulos de cada Activo, sus amenazas y sus técnicas de mitigación.

- Se pedirá que la complete con mínimo 4 activos (los que definirá en el paso 2)

Información/Recursos de datos	Amenazas	Mitigación
• Activo1.1	• Amenaza1 • Amenaza2	• Mitigacion-Amenaza1 • Mitigación-Amenaza2
• Activo1.2	• Amenaza1 • Amenaza2 • Amenaza3	• Mitigacion-Amenaza1 • Mitigación-Amenaza2 • Mitigación-Amenaza3
• Activo1.3	• Amenaza1	• Mitigacion-Amenaza1
• Activo1.4	• Amenaza1 • Amenaza2	• Mitigacion-Amenaza1 • Mitigación-Amenaza2

Activos de software	Amenazas	Mitigación

Activos físicos	Amenazas	Mitigación

Recursos de red	Amenazas	Mitigación

Parte 2: Registre los diferentes tipos de bienes que posee MediTech.

A partir de la información del caso y de su conocimiento del negocio en general, debe encontrar **4 activos** para cada tipo de activo.

Para cada uno de los activos encontrados debe detallar su definición (como información o característica) y su propósito dentro de la organización.

Los diferentes tipos de activos se definen de la siguiente manera:

- **Información/Recursos de datos:** cualquier dato utilizado por la empresa en cualquiera de los tres estados de los datos (en reposo, en tránsito y en uso). **Para cada uno, indique su contenido o propósito.**
Ejemplo: Información médica de los pacientes, datos para gestión, registros de usuarios, historiales de pacientes, datos financieros de pagos, datos de hospitales/clínicas, etc.
- **Recursos de software:** Indicar todo tipo de software utilizado por MediTech, ya sea comercial, personalizado o desarrollado internamente. **Para cada uno, indique su uso o función dentro de la organización.**
Ejemplo: Aplicaciones comerciales de gestión, sistemas operativos, software de servidor, software de bases de datos, plataformas para telemedicina, software personalizado para la gestión de datos médico, etc.
- **Activos físicos:** Incluya todos los dispositivos o equipos utilizados dentro y fuera de las oficinas, incluyendo los que se usan en trabajo remoto. **Para cada uno, describa su función.**
Ejemplo: los dispositivos físicos, equipos médicos, servidores, computadores, tablets, móviles y otros para las operaciones de la compañía.
- **Recursos de red:** Los tipos de redes y conexiones que MediTech aloja o utiliza en el curso de sus operaciones. **Para cada uno, describa el recurso y su función.**
Ejemplo: Redes internas, conexiones remotas, redes de servidores, conexiones con servicios en la nube, etc.

Luego de terminar esta complete las primeras columnas de cada tabla con los activos relevantes que son propiedad de MediTech. Debería tener al menos tres entradas en cada tabla.

Parte 3: Enumere las amenazas para cada tipo de activo.

- Identifique y detalle cada una de las amenazas que podrían aprovechar vulnerabilidades para cada uno de los activos que enumeró en el paso anterior. **Por lo general, hay más de una amenaza para cada recurso.**

Luego de finalizar complete la segunda columna de la tabla con las amenazas que podrían aprovechar vulnerabilidades para cada recurso que enumeró.

Parte 4: Recomiende técnicas de mitigación para hacer frente a cada amenaza.

- Identifique y detalle cada una de las técnicas de mitigación que podrían utilizarse para cada amenaza encontrada en el punto anterior.

Luego de finalizar complete la tercera columna de la tabla con las técnicas de mitigación que podrían frenar las amenazas y vulnerabilidades de cada activo.

Parte 5: Análisis de Riesgos

Con los activos encontrados del caso elabore un análisis de riesgo, utilizando alguna técnica de análisis, que permita establecer la criticidad para cada uno de ellos en caso de que una amenaza pueda concretarse y una matriz de riesgo para identificar los riesgos más relevantes.

- Considere el desarrollo estructurado de las cuatro etapas clave del análisis de riesgos: Análisis, Clasificación, Reducción y Control.
- En cada etapa, detalle claramente las acciones realizadas, los criterios aplicados y las decisiones tomadas.
- Para la etapa de análisis, debe integrarse el uso de al menos una metodología de apoyo para la identificación y comprensión de riesgos, tales como Monte Carlo, FODA, Ishikawa u otra metodología pertinente, justificando la elección.

Además, debe incluirse una matriz de riesgos que permita visualizar de forma clara los activos más expuestos, las amenazas más críticas y las medidas propuestas para su mitigación. Esta matriz debe facilitar la priorización de acciones de seguridad en función de la criticidad del riesgo.

Parte 6: Conteste las siguientes preguntas.

1. ¿Por qué es útil clasificar los recursos al identificar amenazas y técnicas de mitigación?
2. ¿Algunas amenazas tienen medidas de mitigación iguales o similares? ¿Por qué es importante señalar esto?
3. Después de realizar el análisis de riesgo, ¿qué ha aprendido sobre la aplicación del conocimiento sobre amenazas de ciberseguridad y técnicas de mitigación en el contexto de una organización simulada?
4. De acuerdo con las normas revisadas en clases y puestas en el ambiente de aprendizaje, ¿Qué controles y/o objetivos de control de control podría recomendar usted que se encuentren asociado a la familia de la norma 27000?

UTILICE COMO BASA EL FORMATO DE DOCUMENTO DE INACAP, DEJADO JUNTO A ESTE DOCUMENTO EN AAI.



FormatoInforme.docx